

Measuring the Post-Quantum Readiness Gap: From Hyperscale Web to Critical-Infrastructure Endpoints

Azhad Shahzad Shaik 

shaikazhadshahzad@gmail.com <https://github.com/s-shahzad/pqc-readiness-scanner>

July 2026

Abstract

The migration of TLS to post-quantum (PQC) hybrid key exchange is underway but uneven. Under a *harvest-now, decrypt-later* (HNDL) threat model, any endpoint that still negotiates only classical key exchange today is recordable now and decryptable once a cryptographically relevant quantum computer exists. We present a lightweight, handshake-only measurement tool that classifies a TLS 1.3 endpoint as **migrated** (negotiates a PQC hybrid group such as X25519MLKEM768 by default), **classical-only**, or **downgradeable** (PQC-capable but classical by default), and emits a per-host readiness verdict. A calibration scan of 40 prominent web endpoints finds 56.8% of resolvable hosts negotiate PQC by default while 43.2% remain classical-only. That cohort includes, notably, the standards body that published ML-KEM (nist.gov), the OpenSSL project site, and several cryptography-research universities. A scan of 124 OT/IoT/critical-infrastructure-relevant endpoints (104 resolved) finds the gap is vertical-specific rather than blanket: EV-charging portals (32% classical-only) and building-HVAC (0%) lead the web, and energy/grid matches it (48%), but **industrial-automation vendors lag markedly at ~67% classical-only** (31 named vendors, including Siemens, Schneider Electric, Honeywell, ABB, GE Vernova, Bosch Rexroth, Fanuc, and Keyence), versus 43% for the web baseline. We also observe post-quantum hybrid key exchange reaching a real IoT protocol endpoint (a public MQTT-over-TLS broker). The deepest exposure, the device and control-plane endpoints themselves, is not publicly measurable and motivates access-based follow-on work. We release a reproducible scan harness and dataset to make readiness continuously measurable.

1 Introduction

Post-quantum key establishment is now standardized (NIST FIPS 203, ML-KEM [1]) and shipping: major browsers and CDNs negotiate hybrid X25519+ML-KEM-768 by default [11]. But migration is a property of *deployed systems*, not of standards. The interesting failures are in the field: endpoints that never migrated, endpoints that *can* do PQC but do not by default, and endpoints that can be silently downgraded.

This matters because of the HNDL adversary [2]: a network observer can record classical TLS handshakes today and recover session keys later. The exposure window is the time a given endpoint stays classical-only, multiplied by the sensitivity and lifetime of the data it carries. For consumer web, that window is closing. For critical infrastructure (energy, payments, industrial control, healthcare devices), the systems are long-lived, rarely updated, and largely unmeasured.

Contributions.

1. A handshake-only, reproducible PQC-readiness scanner that classifies TLS 1.3 endpoints and issues per-host and fleet verdicts, with a CI-gating exit code (§4).
2. A calibration baseline over 40 prominent web endpoints, with the surprising result that several cryptography authorities themselves remain classical-only (§5).
3. A focused measurement of 124 OT/IoT/critical-infrastructure endpoints, the vertical with the largest exposure window and the least existing data (§6).
4. A released harness and dataset, and a responsible-disclosure / ethics protocol (§7).

Scope and differentiation. Concurrent 2026 work measures PQC readiness of the *generic web* [8, 9]. We deliberately do **not** compete there. Our web scan is a calibration baseline; our contribution is the OT/IoT/critical-infrastructure vertical, where the author has prior standing (first-author IEEE GCAIoT 2025 work on OCPP EV-charging security [15]).

2 Background

TLS 1.3 key exchange and named groups. Classical groups: X25519, secp256r1/prime256v1, secp384r1, secp521r1. PQC hybrid groups: X25519MLKEM768, SecP256r1MLKEM768, X448MLKEM1024 (and earlier *Kyber768* drafts), as specified for TLS 1.3 hybrid key agreement [3].

ML-KEM (FIPS 203) and hybrids. Hybrid constructions combine a classical ECDH with a lattice KEM so that security holds if *either* component holds [1, 6].

HNDL threat model. Under harvest-now, decrypt-later [2], the security-relevant property is what an endpoint negotiates *by default* with a standard client, not what it is merely capable of. Capability without default negotiation still leaves every ordinary connection recordable. This motivates measuring default-negotiation and capability separately.

3 Related Work

Internet-wide TLS measurement. ZMap [4] and Censys [5] established Internet-scale TLS scanning as a security-measurement instrument. Our tool is deliberately smaller: a single-file, handshake-only prober designed for auditable, low-volume scans of named critical endpoints rather than full address-space sweeps.

PQC-in-TLS performance and deployment. Paquin et al. [6] and Sikeridis et al. [7] established that post-quantum key exchange and authentication are practical in TLS 1.3. Industry telemetry [11] tracks client-side adoption at CDN scale. Two concurrent 2026 efforts are closest to ours: Ibrahim et al. [8] detect PQC and hybrid TLS key exchange by raw TLS-record inspection of ServerHello key-share identifiers (38 production endpoints), and Delgado [9] proposes a multi-surface observability framework that separates session evidence, endpoint capability, and certificate-chain evidence at the scale of 1,000 targets. Both build detection methodology and observability infrastructure for the generic web. We differ in the measured population and the question asked: a vertical census of OT/IoT/critical-infrastructure organizations, asking *which sectors* lag. Our default-vs-capability distinction (the *downgradeable* class) is consistent with the capability-vs-session separation that Delgado also emphasizes; HNDL makes it security-relevant.

Cryptography deployment gaps. Albrecht and Paterson [10] document the recurring gap between standardized cryptography and what deployed systems actually do; our results are a PQC-era instance of that gap, reaching even cryptography-authority organizations.

Constrained and OT protocols. PQC integration into constrained-device protocols is active in the IETF (EDHOC/OSCORE for IoT [12]). Operational OT/IoT protocols in our scan population include MQTT-over-TLS [13] and OCPP for EV charging [14]; prior work by the author examined OCPP security [15]. To our knowledge no prior public measurement reports PQC default-negotiation rates for the industrial-automation vendor population.

4 Methodology

The scanner completes a normal TLS 1.3 handshake against a target and parses the negotiated group; it is a measurement tool, not an attack tool.

- **Default probe.** Connect with the client’s default group preference; read **Negotiated TLS1.3 group:** (OpenSSL 3.x), falling back to **Peer Temp Key:**. Classify the negotiated group as **pqc-hybrid**, **classical**, or **unknown** (normalized match: any group containing **mlkem/kyber** $\Rightarrow$ hybrid).
- **Capability probe.** If the default is not hybrid, reconnect offering only PQC groups (**X25519MLKEM768:SecP256K1**). If the host then negotiates a hybrid, it is **downgradeable** / **partial** (capable but classical by default); otherwise **classical-only**.
- **Verdict per host:** **MIGRATED** | **PARTIAL** (PQC available, classical by default) | **CLASSICAL ONLY** (HNDL-exposed) | **UNKNOWN**.
- **Fleet rollup and CI gate:** non-zero exit if any host is classical-only so the scanner can serve as a migration regression gate.
- **Requirements:** OpenSSL 3.5+ (or an OQS-enabled build) for PQC detection; classical detection works with any modern OpenSSL.

Reproducibility: single-file Python wrapper over `openssl s_client`, deterministic classification, JSON output. The harness and host lists are released.

5 Results: Web Calibration Baseline

We scanned 40 prominent web endpoints on 2026-06-25 (37 resolvable).

Class	Count	% of all (40)	% of resolvable (37)
Migrated (PQC hybrid by default)	21	52.5%	56.8%
Classical-only (HNDL-exposed)	16	40.0%	43.2%
Unknown (group undetermined)	3	7.5%	—

Table 1: Web calibration baseline, $N = 40$, 2026-06-25.

Migrated (21): google, cloudflare, facebook, instagram, youtube, apple, wikipedia, x, reddit, openai, anthropic, signal, bankofamerica, paypal, berkeley, oxford, cambridge, gov.uk, bbc, nytimes, wordpress. Hyperscalers and CDNs dominate, consistent with edge-driven rollout.

Classical-only (16): amazon, microsoft, github, linkedin, netflix, mozilla, **openssl.org**, proton.me, chase, stripe, **ethz.ch**, **tudelft.nl**, **ru.nl**, **nist.gov**, europa.eu, yahoo.

Notable findings.

- **nist.gov**, the body that published FIPS 203 (ML-KEM), negotiated **classical-only** by default at scan time.
- **openssl.org** and the cryptography-research universities **ETH Zürich**, **Radboud (ru.nl)**, and **TU Delft** were classical-only; the migration lag reaches even cryptography-aware organizations.
- **Payments split:** Chase and Stripe were classical-only while Bank of America and PayPal had migrated. Sector behavior is not uniform.
- Three hosts (eff.org, mit.edu, stanford.edu) returned an undetermined group under our single-vantage probe (see §8).

Interpretation: PQC default-negotiation correlates with running behind a small set of migrated front-ends (Google, Cloudflare, Meta, Apple edges), not with the cryptographic sophistication of the organization. Capability $\neq$ default; default $\neq$ awareness.

6 Results: Critical-Infrastructure Endpoints

We scanned 124 OT/IoT/critical-infrastructure-relevant endpoints across six verticals with the same default+capability probe (2026-06-25). **Scope note:** except for the MQTT brokers (real IoT protocol endpoints on :8883), these are the *public web frontends* of the operators and vendors, not the embedded control-plane, charge-point, or RTU devices (which are not publicly scannable). They proxy organizational PQC posture, not device endpoints; this is a limitation, not a result. 104 of 124 resolved (20 returned no group under our 8 s single-vantage probe: anycast, middleboxes, or timeouts).

Vertical	Resolvable	Migrated	Classical-only	Classical %
OT/ICS automation (industrial)	46	15	31	67%
MQTT-over-TLS brokers (:8883)	3	1	2	67%
Energy / grid operators	33	17	16	48%
EV-charging / OCPP operators	19	13	6	32%
Building automation (HVAC)	3	3	0	0%
OT/IoT total	104	49	55	53%
<i>Web baseline (§5)</i>	37	21	16	43%

Table 2: OT/IoT/critical-infrastructure scan, $N = 124$ (104 resolved), 2026-06-25.

Figure 1 plots the per-vertical rates in Table 2; the vertical ordering makes the single clear signal visible: industrial automation is the lone laggard, while EV-charging and building-HVAC sit below the web baseline.

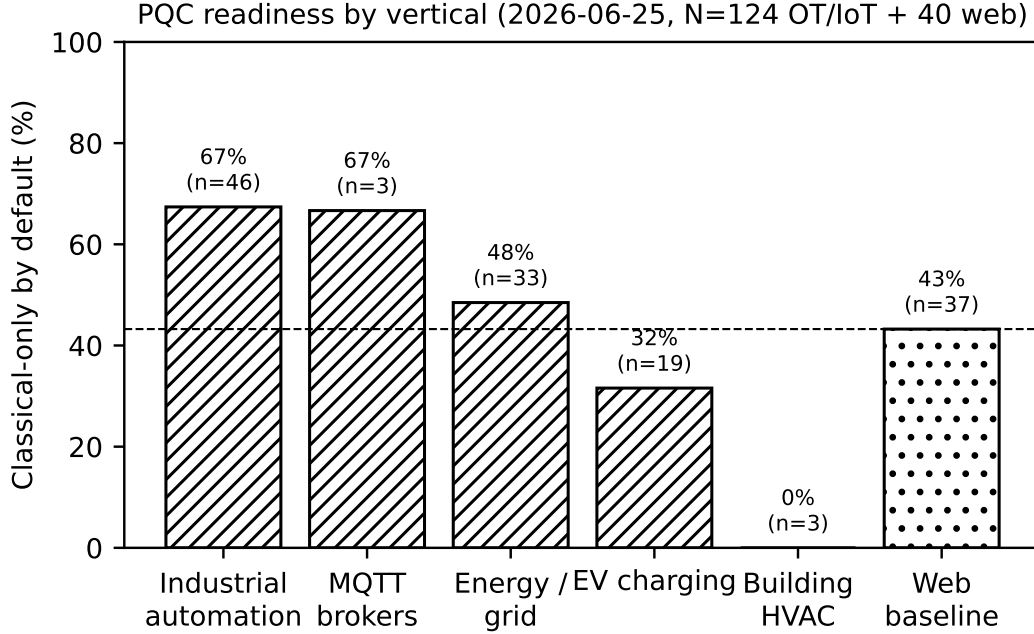


Figure 1: Default classical-only rate by vertical, computed directly from the released scan results. Bars are labelled with the resolvable sample size per vertical; the dashed line marks the 43% web baseline. Industrial-automation vendors are the only vertical materially above the web baseline.

Findings.

- **Industrial-automation vendors are the laggard vertical: 67% classical-only by default** (31/46 resolved), markedly above the 43% web baseline and the highest of any vertical. The classical-only cohort includes **Siemens, Schneider Electric, Honeywell, ABB, GE Vernova, Bosch Rexroth, Fanuc, Keyence, Festo, Phoenix Contact, SICK, Endress+Hauser, Pepperl+Fuchs, Lenze, Danfoss, Parker, ifm, Weidmüller, Moxa, Hitachi Energy, Red Lion, Lantronix, AspenTech, Inductive Automation** and more. Migrated automation vendors were the minority (Emerson, Beckhoff, WAGO, Pilz, Turck, HMS, Advantech, Yaskawa, Digi, ...).
- **EV-charging leads the web (32% classical):** consumer portals are CDN-fronted and largely migrated; classical-only were Tesla, Blink, EVBox, Alfen, GridServe. Migration tracks the front-end CDN, not the sector.
- **Energy/grid mirrors the web (48%):** migrated (National Grid, ISO-NE, Southern Co, Dominion, Enel, E.ON, MISO, ERCOT, TenneT, Xcel, ConEd, SCE, ...) vs. classical-only (Duke, US eia.gov, EU entsoe.eu, PSEG, NextEra, EDF, Iberdrola, Vattenfall, RTE, Terna, ...).
- **Building automation (HVAC) is fully migrated** (Johnson Controls, Trane, Carrier; 3 of 3), a clean contrast with industrial automation.
- **PQC reaches real IoT protocol endpoints:** `test.mosquitto.org:8883` negotiated X25519MLKEM768 (broker.emqx.io and mqtt.flespi.io were classical-only). Hybrid key exchange is viable on MQTT-over-TLS today.

Reading. The gap is **vertical-specific, not blanket**. The early small-sample “OT lags everywhere” hypothesis did not survive scaling: EV-charging and building-HVAC actually lead the web, and energy matches it. What holds, and stays stable from $N=24$ (71%) through $N=46$ (67%) resolved vendors, is that **heavy-industrial automation vendors lag markedly** ($\sim 67\%$ **classical-only**), which is the concrete, defensible contribution. The deeper device/control-plane exposure (RTUs, PLCs, OCPP central systems) remains unmeasurable from the public Internet; quantifying it requires operator or laboratory access, which is precisely the follow-on research program this measurement motivates.

6.1 Longitudinal stability (first re-scan, $T_0 + 7$ days)

We re-ran the identical probe (same host lists, same 8 s single-vantage methodology, same OpenSSL 3.5.6 build) on 2026-07-02, seven days after the baseline, to separate real migration movement from measurement noise.

Population	Hosts compared	Verdict unchanged	Migrations observed
OT/IoT ($N=124$)	124	123 (99.2%)	0
Web ($N=40$)	40	40 (100%)	0

Table 3: Longitudinal re-scan, 2026-06-25 $\rightarrow$ 2026-07-02. The single changed verdict (aspentech.com: classical-only $\rightarrow$ unknown) returned no negotiated group within the probe window, a vantage/timeout artifact rather than a class change.

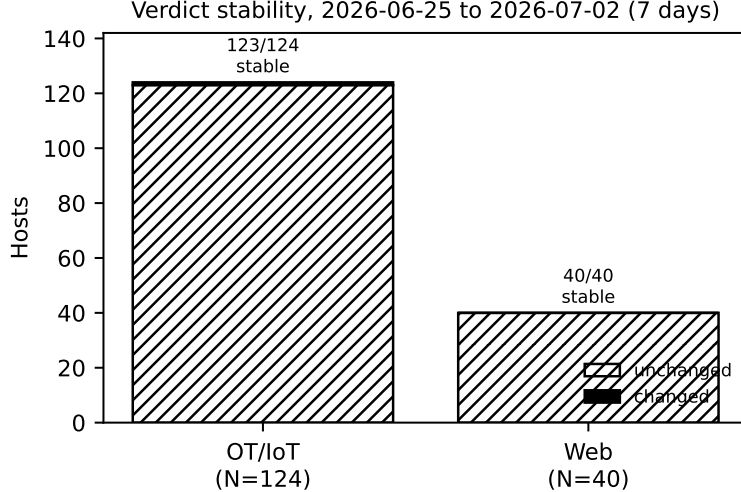


Figure 2: Verdict stability across the two runs, computed from the released baseline and re-scan JSON. 163 of 164 host verdicts are identical one week apart.

Two things follow (Table 3, Figure 2). First, verdict stability of 99.4% (163/164) across independent runs a week apart is direct evidence that the single-vantage handshake classification is reproducible rather than a per-connection artifact. Second, no endpoint in either population migrated to post-quantum key exchange over the interval: every classical-only host at the baseline, including the industrial-automation cohort and the cryptography-authority sites, remained classical-only. At this cadence, OT/ICS PQC migration is effectively flat week-to-week, which

sharpens the long-exposure-window concern that motivates the study. We will continue the re-scan on a monthly cadence to recover the migration slope.

Next steps. Continued longitudinal re-scans to chart the migration slope; lawful device-plane endpoints via disclosure partners; multi-vantage probing to recover the 20 unresolved hosts.

7 Ethics and Responsible Disclosure

- Handshake-only; no payloads, no denial of service, no exploitation. Load is equivalent to a single browser connection per probe.
- Public, owner-operated endpoints only; abuse contacts honored; rate-limited.
- Named high-value classical-only sites are disclosed privately before publication where appropriate.
- The released dataset contains only hosts that are already public infrastructure; no credentials, no personal data.

8 Limitations

- Single network vantage point: middleboxes and anycast can yield UNKNOWN or vantage-specific results (3/40 in the web baseline). Multi-vantage scanning is planned.
- Default negotiation depends on the client’s offered preference order; we fix it and document it.
- The $N=40$ web baseline is illustrative, not representative; the contribution rests on the OT/IoT vertical (§6), not the web N .
- Point-in-time snapshot; migration is moving, and the longitudinal scan addresses this.

9 Conclusion

PQC migration is real but front-end-driven and deeply uneven: even NIST’s and OpenSSL’s own sites, and cryptography universities, were classical-only at scan time. The consequential gap is in OT/IoT/critical-infrastructure endpoints, where industrial-automation vendors lag at $\sim 67\%$ classical-only against a 43% web baseline. We release the scanner and dataset to make PQC-readiness a continuously measurable property rather than an assumption.

Artifacts. Scanner: <https://github.com/s-shahzad/pqc-readiness-scanner> (pqc_scan.py, MIT license). Datasets: scan-results.json (web baseline), seed-ot-iot{-2,-3}.json (OT/IoT scans, 2026-06-25), rescan-{ot-iot,web}-2026-07-02.json (longitudinal re-scan), with the per-run comparison in LONGITUDINAL.md. Figures are regenerated from these files by make_figures.py.

References

- [1] National Institute of Standards and Technology. Module-Lattice-Based Key-Encapsulation Mechanism Standard. FIPS 203, August 2024.
- [2] M. Mosca. Cybersecurity in an era with quantum computers: Will we be ready? *IEEE Security & Privacy*, 16(5):38–41, 2018.
- [3] K. Kwiatkowski, P. Kampanakis, B. Westerbaan, and D. Stebila. Post-quantum hybrid ECDHE-MLKEM key agreement for TLSv1.3. IETF Internet-Draft, draft-ietf-tls-ecdhe-mlkem, work in progress.
- [4] Z. Durumeric, E. Wustrow, and J. A. Halderman. ZMap: Fast Internet-wide scanning and its security applications. In *USENIX Security Symposium*, 2013.
- [5] Z. Durumeric, D. Adrian, A. Mirian, M. Bailey, and J. A. Halderman. A search engine backed by Internet-wide scanning. In *ACM CCS*, 2015.
- [6] C. Paquin, D. Stebila, and G. Tamvada. Benchmarking post-quantum cryptography in TLS. In *PQCrypto*, 2020.
- [7] D. Sikeridis, P. Kampanakis, and M. Devetsikiotis. Post-quantum authentication in TLS 1.3: A performance study. In *NDSS*, 2020.
- [8] M. Ibrahim, V. Ajith, and M. S. Haroon. Detecting post-quantum and hybrid TLS deployments via raw TLS record inspection. Cryptology ePrint Archive, Paper 2026/834, 2026.
- [9] J. L. Delgado. Observability for post-quantum TLS readiness: A multi-surface evidence framework. Cryptology ePrint Archive, Paper 2026/866, 2026.
- [10] M. R. Albrecht and K. G. Paterson. Analysing cryptography in the wild. Position paper, 2024.
- [11] B. Westerbaan. The state of the post-quantum Internet. Cloudflare blog, 2024. <https://blog.cloudflare.com/pq-2024/>.
- [12] G. Selander, J. Preuß Mattsson, and F. Palombini. Ephemeral Diffie-Hellman over COSE (EDHOC). RFC 9528, 2024.
- [13] OASIS. MQTT version 5.0. OASIS Standard, 2019.
- [14] Open Charge Alliance. Open Charge Point Protocol 2.0.1. 2020.
- [15] A. S. Shaik, M. Gutla, A. P. R. Kagitala, and S. Bhatia. Plugged-in and protected: Leveraging machine learning to secure IoT-based electric vehicle charging stations from denial-of-service threats. In *IEEE Global Conference on Artificial Intelligence and Internet of Things (GCAIoT)*, 2025. DOI: 10.1109/GCAIoT68269.2025.11275540.